

Windows Active Directory is the identity and access management backbone of most enterprise environments. At its core, AD relies on a domain controller (DC) to authenticate users and computers within a domain. In this lab environment, DC01 serves as the domain controller and WS01 is a domain-joined workstation. When a user logs on to WS01, the workstation does not authenticate the credential locally; instead, it forwards the authentication request to DC01, which validates the credential against the AD database and either grants or denies access. This architecture centralizes authentication, which simplifies management but also creates a single point of failure that attackers routinely target.

Active Directory supports two primary authentication protocols: Kerberos version 5 and NT LAN Manager (NTLM). Kerberos is the default and preferred protocol in modern domain environments. It operates on a ticket-granting model where WS01 requests a Ticket Granting Ticket (TGT) from the Key Distribution Center (KDC) running on DC01. Once a TGT is obtained, the client can request service tickets to access specific resources without re-entering credentials. NTLM, by contrast, is a challenge-response protocol used as a fallback when Kerberos is unavailable, such as when a resource is accessed by IP address rather than hostname. Because NTLM sends a password-derived hash in its exchange, it is considered less secure and is a frequent target in pass-the-hash attacks (Achuthan & Suresh, 2024).

The distinction between Kerberos and NTLM is critical for detection purposes. Kerberos failures generate different event IDs than NTLM failures, and an analyst must understand which protocol was in use to correctly interpret the log data. In environments where legacy applications force NTLM usage, the attack surface is larger because NTLM does not support mutual authentication, meaning a client cannot verify the identity of the server it is communicating with. This weakness has been exploited in relay attacks where an attacker intercepts an NTLM authentication exchange and replays it against a different server to gain unauthorized access (Srinivasan & Bhattacharya, 2023).

Effective detection of authentication attacks depends on proper audit policy configuration. In this lab, advanced audit policies were applied to DC01 using Group Policy. Specifically, the following audit subcategories were enabled: Audit Logon Events, Audit Account Logon Events, and Audit Account Management. These policies instruct the operating system to write security events to the Windows Security event log whenever authentication activity occurs, whether successful or failed. Four event IDs are central to this analysis. Event ID 4624 is generated for every successful logon and captures the logon type, authentication package, and source IP address. Event ID 4625 is generated for every failed logon attempt and includes a failure reason code, such as 0xC000006A (wrong password) or 0xC0000234 (account locked out). Event ID 4771 is specific to Kerberos and is logged when pre-authentication fails, typically due to a bad password entered against a Kerberos-enabled account. Event ID 4776 is logged onto the domain controller when it attempts to validate NTLM credentials, and the result field indicates success or failure. Together, these event IDs provide a detailed forensic record of authentication activity on the domain (NIST, 2020). Configuring these audit policies correctly is not trivial. Windows provides both basic and advanced audit policy settings, and the advanced settings override the basic ones when both are configured. If an administrator enables only the basic "Audit logon events" policy, the system generates a broad set of events that may include

noise unrelated to credential attacks. The advanced audit subcategories allow more granular control, enabling an analyst to capture only the specific events needed for detection without flooding the log with irrelevant data. In production environments, log volume management is a persistent challenge because domain controllers in large organizations can generate millions of authentication events per day (Koroniotis et al., 2023).

To simulate a brute force attack, repeated failed logon attempts were generated from WS01 against a domain user account on DC01. A PowerShell script executed in a controlled environment sent authentication requests in rapid succession using incorrect passwords. Within seconds, DC01 began logging a high volume of Event ID 4625 entries, each with failure reason 0xC000006A. Simultaneously, Event ID 4771 entries appeared, confirming that the failed attempts were directed at Kerberos-protected accounts. Analysis of the event log revealed several patterns consistent with brute force activity. First, more than twenty failed logon events were recorded within a sixty-second window, all originating from the same source IP address assigned to WS01. Second, all failed attempts targeted the same account name. Third, the failure reason code remained constant across all entries, indicating a systematic password-guessing attempt rather than isolated user error. These patterns are precisely what a security analyst would flag when reviewing logs manually or configuring a SIEM alert rule. According to Salim et al. (2022), temporal clustering of failed authentication events is one of the most reliable indicators of automated credential attacks.

The simulation also revealed the importance of log timestamps. Event log entries in Windows record timestamps to the second, which is sufficient for detecting rapid automated attacks but may be insufficient for distinguishing between two separate manual attempts that happen to fall within the same second. In forensic scenarios where attribution matters, supplemental data sources such as network packet captures or endpoint detection and response (EDR) telemetry can provide millisecond-level precision to support the timeline analysis.

While manual log review was sufficient for this controlled lab environment, real-world detection at scale requires automated tooling. Security Information and Event Management (SIEM) platforms aggregate logs from multiple sources, including domain controllers, workstations, firewalls, and VPN concentrators, into a centralized repository where correlation rules can be applied. A basic brute force detection rule in a SIEM might trigger an alert when five or more Event ID 4625 entries from the same source IP address are observed within a thirty-second window. More sophisticated rules incorporate additional context, such as whether the targeted account is a privileged account or whether the source IP is internal versus external (Koroniotis et al., 2023).

In this lab, the detection approach was validated by writing a PowerShell script that parsed the Security event log on DC01 and filtered for clusters of Event ID 4625 entries. The script grouped events by source IP address and account name, then flagged any combination that exceeded the threshold of five failures within sixty seconds. This approach mirrors the logic that a SIEM correlation rule would apply, but at a smaller scale suitable for a single domain controller. The script also cross-referenced Event ID 4624 entries to determine whether any successful logon followed the burst of failures, which would indicate a potential account compromise rather than a simple failed attack.

Beyond threshold-based detection, behavioral analytics offer a more advanced approach. User and Entity Behavior Analytics (UEBA) platforms establish baseline authentication patterns for each user account, including typical logon times, source devices, and geographic locations. When an authentication event deviates significantly from the baseline, the system generates an anomaly alert even if the absolute number of failures does not exceed a fixed threshold. This approach is particularly effective against slow brute force attacks, also known as password spraying, where an attacker tries one or two passwords against many accounts to stay below lockout thresholds (Srinivasan & Bhattacharya, 2023).

The most direct mitigation against brute force attacks in an Active Directory environment is account lockout policy. In this lab, Group Policy was configured to lock an account after five consecutive failed logon attempts within a thirty-minute observation window, with a lockout duration of fifteen minutes. Once the brute force simulation reached the lockout threshold, DC01 generated Event ID 4740 (Account Locked Out) and subsequent authentication attempts from WS01 immediately failed with failure reason 0xC0000234, indicating the account was locked. This effectively halted the attack, demonstrating that even a basic lockout policy provides a significant barrier against automated credential guessing.

Beyond account lockout, password complexity requirements enforced via Group Policy reduce the probability that any single guessed password will be correct. Requiring a minimum length of twelve characters with mixed character classes substantially increases the search space an attacker must navigate. Microsoft currently recommends a minimum password length of fourteen characters and discourages periodic password rotation in favor of monitoring for compromised credentials through services such as Azure AD Password Protection, which checks proposed passwords against a global banned password list (Microsoft, 2024).

Multi-factor authentication (MFA) represents the most effective control against credential-based attacks because it requires the attacker to compromise a second authentication factor in addition to the password. Even if a brute force attack successfully guesses the correct password, the attacker cannot complete authentication without access to the second factor, which is typically a time-based one-time password (TOTP), a push notification to a mobile device, or a hardware security key. Organizations that have deployed MFA across all user accounts report a reduction of more than 99 percent in account compromise incidents compared to password-only environments (CISA, 2024).

In enterprise environments, these controls are supplemented by SIEM systems that aggregate event logs from multiple domain controllers and workstations. A SIEM can apply correlation rules such as alerting on five or more Event ID 4625 entries from the same source IP within thirty seconds, enabling real-time detection and automated response. NIST SP 800-53 Rev. 5 provides a comprehensive framework of controls applicable to this scenario, including AC-7 (Unsuccessful Logon Attempts), IA-5 (Authenticator Management), and AU-12 (Audit Record Generation), all of which were operationalized in this lab environment (NIST, 2020).

The techniques demonstrated in this lab directly mirror the methods used by threat actors in production environments. The 2024 Verizon Data Breach Investigations Report found that credential-based attacks, including brute force and credential stuffing, accounted for a significant portion of confirmed breaches across all industry verticals. Attackers frequently target externally facing services such as Remote Desktop Protocol (RDP), VPN gateways, and

Liam Jones

Exploring Active Directory Authentication Attacks

Spring 2026

web-based email portals with automated credential attacks. Once initial access is obtained through a compromised account, lateral movement within the network often leverages the same Active Directory infrastructure that was analyzed in this lab (Verizon, 2024).

The relevance of this research extends beyond technical detection. Regulatory frameworks including the Health Insurance Portability and Accountability Act (HIPAA), the Payment Card Industry Data Security Standard (PCI DSS), and the Federal Information Security Modernization Act (FISMA) all require organizations to implement controls for detecting and responding to unauthorized access attempts. The audit policies, lockout configurations, and log monitoring techniques described in this report satisfy specific compliance requirements within each of these frameworks. For organizations subject to multiple regulatory regimes, a well-configured Active Directory logging and detection pipeline serves as a foundational control that supports compliance across all applicable standards (NIST, 2020).

This research demonstrated that authentication attacks against Active Directory can be detected reliably through properly configured audit policies and systematic event log analysis. The controlled lab environment provided a repeatable platform for simulating brute force attacks and validating detection logic against the resulting event data. The key event IDs, specifically 4624, 4625, 4771, 4776, and 4740, form a complete forensic record of credential attack activity when the corresponding audit subcategories are enabled on the domain controller. The defensive controls tested in this lab, including account lockout policies, password complexity requirements, and threshold-based detection scripts, are effective against basic brute force attacks. However, more sophisticated threats such as password spraying and credential stuffing require correspondingly advanced defenses, including UEBA platforms, multi-factor authentication, and integration with threat intelligence feeds that identify compromised credentials before they are used against the organization. Future work could expand this lab to include simulation of pass-the-hash and Kerberoasting attacks, which exploit different weaknesses in the Active Directory authentication architecture and require distinct detection strategies.

References

- Achuthan, K., & Suresh, K. (2024). Advancing cybersecurity and privacy with artificial intelligence. *Frontiers in Big Data*, 7, Article 1497535.
<https://doi.org/10.3389/fdata.2024.1497535>
- Cybersecurity and Infrastructure Security Agency. (2024). Multi-factor authentication. CISA.
<https://www.cisa.gov/MFA>
- Koroniotis, N., Moustafa, N., & Sitnikova, E. (2023). A holistic review of cybersecurity and reliability perspectives in smart grids. *IEEE Access*, 11, 47643–47668.
<https://doi.org/10.1109/ACCESS.2023.3275420>
- Microsoft. (2024). Password policy recommendations. Microsoft Learn.
<https://learn.microsoft.com/en-us/microsoft-365/admin/misc/password-policy-recommendations>
- National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (SP 800-53 Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>
- Salim, M. M., Rathore, S., & Park, J. H. (2022). Distributed denial of service attacks and its defenses in IoT: A survey. *The Journal of Supercomputing*, 78(4), 5320–5363.
<https://doi.org/10.1007/s11227-022-04841-9>
- Srinivasan, S., & Bhattacharya, P. (2023). Anomaly detection in network traffic using machine learning: A review. *International Journal of Advanced Computer Science and Applications*, 14(2), 112–120. <https://doi.org/10.14569/IJACSA.2023.0140215>
- Verizon. (2024). 2024 Data Breach Investigations Report. Verizon Business.
<https://www.verizon.com/business/resources/reports/dbir/>